공격

민간에서 불법으로 만드는 대포폰은 통신망에 쉽게 걸리고 쉽게 털려서 랜섬웨어같은거에 쉽게 감염되고 기업이 점검 용으로 만드는 정당한 대포폰은 백도어 보안키를 여러층으로 우회하고 클라우드 온프라미스 로컬 pc접속때는 이삼중 백도어로 라우팅 프로토콜로 ddos 오버플로우 인젝션 공격을 일부 허용한다 그리고 접속 해제 시 ip주소 tcp,udp 경로를 복호화 시키고 (RSA) 이외에 위치와 식별번호는 암호화 시킨다(AES)

방어

——— 1. 커널·네트워크 하드닝 (오버플로우 완화 + DDoS 방어) ———

sudo tee /etc/sysctl.d/99-hardening.conf >/dev/null <<'EOF'
kernel.randomize_va_space = 2 # ASLR full
kernel.dmesg_restrict = 1
kernel.yama.ptrace_scope = 1 # 프로세스 메모리

열람 제한
net.ipv4.tcp_syncookies = 1 # SYN flood 방어
net.ipv4.tcp_max_syn_backlog = 2048
net.ipv4.tcp_synack_retries = 2
net.ipv4.conf.all.rp_filter = 1 # IP 스푸핑 차단
net.ipv4.icmp_echo_ignore_broadcasts = 1 #
smurf 방어
EOF
sudo sysctl --system

——— 2. 방화벽 레이트 리밋 (DDoS·과부하)

———————————————————————————————

IP당 동시 연결 20개 초과 거부

sudo iptables -A INPUT -p tcp --dport 80 -m
connlimit

--connlimit-above 20 -j REJECT

새 연결 속도 제한 (초당 25, 버스트 50)

sudo iptables -A INPUT -p tcp --dport 80 -m conntrack --ctstate NEW
-m hashlimit --hashlimit-name http --hashlimit-mode srcip
--hashlimit-above 25/sec --hashlimit-burst 50 -j DROP

——— 3. 리소스 제한 (과부하·포크밤 방어)

———————————————————————————————

echo '* hard nproc 1024' | sudo tee -a /etc/security/limits.conf
echo '* hard nofile 4096' | sudo tee -a /etc/

security/limits.conf

systemd 서비스 단위 제한: sudo systemctl edit myapp

[Service]

MemoryMax=512M

TasksMax=256

LimitNOFILE=4096

——— 4. 서비스 격리 (인젝션 피해 최소화)

_____

sudo useradd -r -s /usr/sbin/nologin appsvc # 비루트 전용 계정
sudo aa-status # AppArmor(우분투) 적용 확인
getenforce # SELinux(RHEL) → Enforcing 여야 함

——— 5. 반복 공격 자동 차단

---

sudo apt install fail2ban -y
sudo systemctl enable --now fail2ban